



NETWORK SECURITY | MODULE 5

Legal, Ethical and Policy Issues

Lesson 5 – Key Escrow

Lesson 8 – Legal Issues



Key escrow · Privacy · Digital signatures · IT Act 2000 · Indian laws · Patents



LESSON 5: KEY ESCROW

- 1 **The Escrow Dilemma**
Lawful wiretaps vs. privacy
- 2 **Clipper and EES**
Chips, split keys and escrow agencies
- 3 **Trustee-Based Escrow**
Splitting a private key among n trustees
- 4 **Politics of Key Escrow**
Who gains, who loses

LESSON 8: LEGAL ISSUES

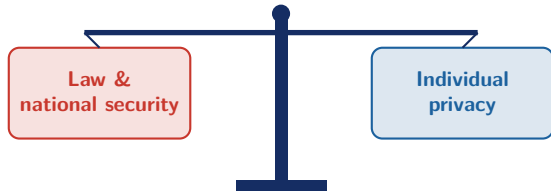
- 5 **Ethics and Law**
Privacy, PAPA, digital signatures
- 6 **Indian Cyber Law**
IT Act 2000 and its key sections
- 7 **Other Indian Acts**
Contract, IPC, Copyright, Consumer, Relief
- 8 **Initiatives, Patents, Exports**
STQC, CERT-In, ISTDC, RSA patent



Lesson 5

Key Escrow

The Dilemma: Lawful Wiretaps vs. Privacy



- Court-authorized **line tapping** helps bring criminals to justice and deters unlawful use of networks
- Widespread public-key cryptography may be a **boost for criminals and terrorists**
- Many bills propose that a government agency should be able to obtain the **clear text** of any communication, under law

The challenge

Build a cryptosystem that **protects privacy** but still allows **court-authorized wiretaps**.

Two Unpopular Options



Give the authorities readable traffic by...

(1) Using weak crypto systems

Systems the authorities can crack with moderate effort, **but so can everybody else**

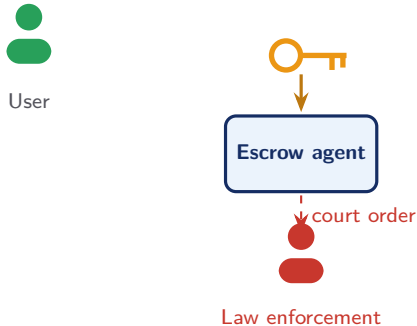
(2) Surrendering your secret key

Hand your key to the authority **in advance**, before any crime is suspected

Public reaction

Both alternatives alarmed many citizens, who felt that **privacy should come before** national security and law enforcement.

What Is Key Escrow?

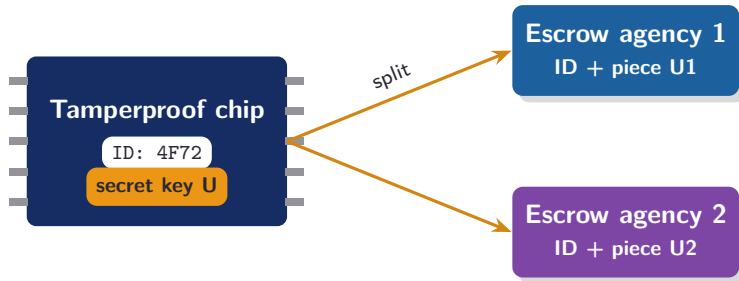


Idea

A copy of the decryption key (or its pieces) is held in **escrow** by trusted agents, and released **only under a court order**.

- The heart of the US government's **Clipper** program
- Formalized as the **Escrowed Encryption Standard (EES)**
- "Escrow" = held by a third party until a condition is met

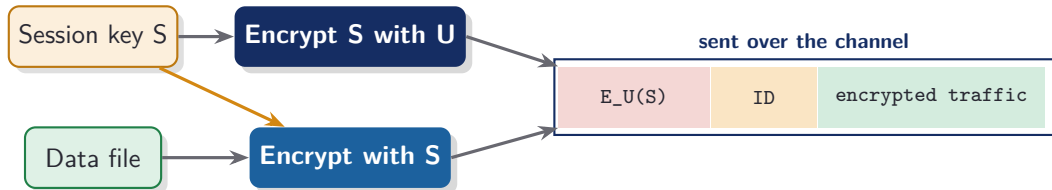
The EES Chip and Its Split Key



$$U = U_1 \oplus U_2$$

- EES gets its security from **tamperproof hardware**
- Each chip has a **unique ID number** and a **secret key**
- The key is split into **two pieces**, stored with the ID by **two different escrow agencies**: neither piece alone reveals anything

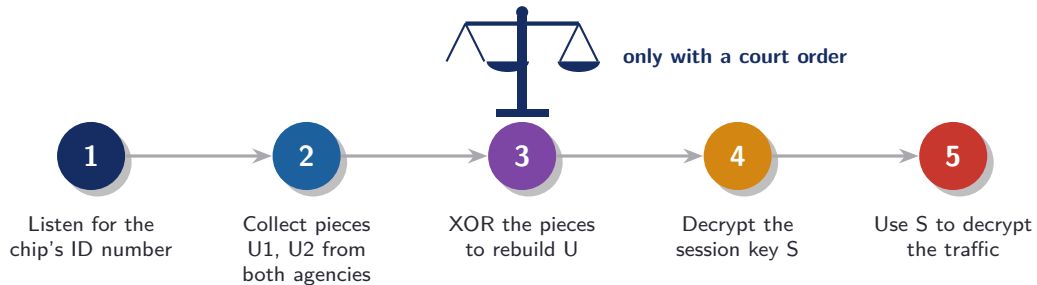
How an EES Chip Sends Data



Every time the chip encrypts

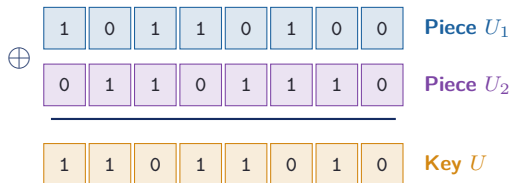
It first encrypts the **session key** with its unique secret key, then sends this encrypted session key and its **ID number** along with the encrypted traffic.

How Law Enforcement Decrypts



The point

Without the court-ordered help of **both** escrow agencies, the traffic stays private, but with it, a lawful wiretap is possible.

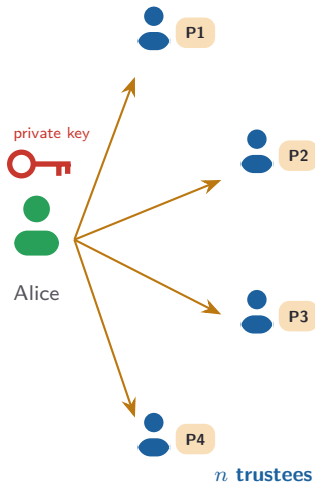


- XOR rule: **same bits give 0**, different bits give 1
- U_1 alone looks completely **random**; so does U_2
- Only $U_1 \oplus U_2$ gives back the real key U

So

One agency, or one thief who robs one agency, learns **nothing** about the key.

Escrow with n Trustees



- Alice's **private key** is broken into pieces and given to different **trustees**
- Like a **secret sharing** scheme: together, the authorities can rebuild the key
- Each trustee can **verify** their piece is valid without rebuilding the key
- Alice cannot cheat by sending a random-bit string

Hard to abuse

To steal Alice's key, Mallory must corrupt **all** n trustees.



1

Alice creates her private/public key pair and splits the private key into several **public pieces** and **private pieces**

2

Alice sends one public piece and its private piece to **each trustee** (encrypted), and sends her public key to the **KDC**

3

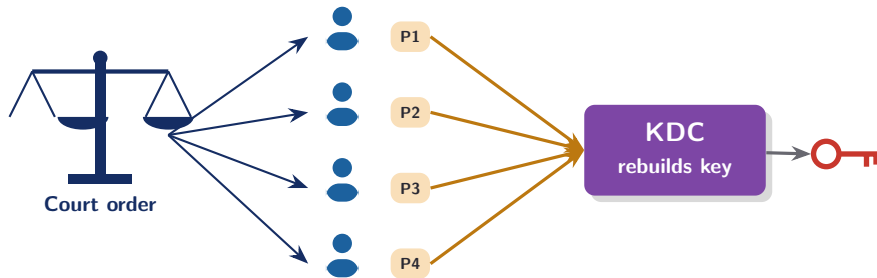
Each trustee independently **checks** its pieces, stores the private piece securely, and sends the public piece to the KDC

4

The KDC checks the public pieces against the public key; if all is correct, it **signs** the public key and returns or publishes it

KDC = Key Distribution Centre.

When the Court Orders a Wiretap



After the order

Each trustee surrenders its piece to the KDC, which reconstructs the private key and can wiretap Alice.

Before the order

Neither the KDC nor any single trustee can rebuild the key: **all trustees** are required.



Advantages for the user
“really aren’t any”

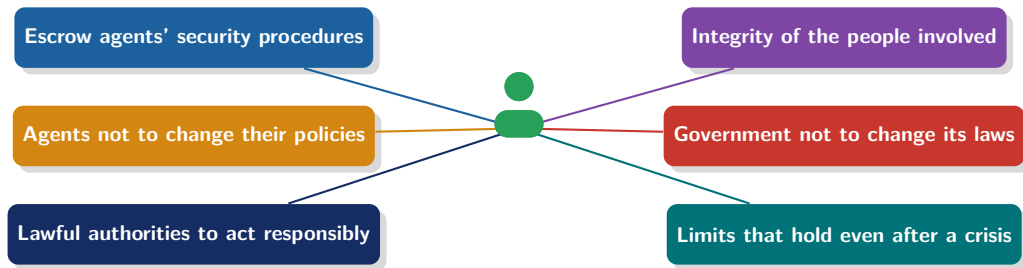
Several **commercial** key-escrow proposals exist besides the government’s. But the user gains nothing he could not provide himself:

- He can already **back up his own keys**
- Escrow guarantees the **police can eavesdrop** on his conversations and read his files, even though encrypted
- It guarantees the **NSA can eavesdrop** on international calls, **without a warrant**
- Perhaps he may use crypto in countries that would ban it, the **only advantage**

The Politics: Considerable Disadvantages



The user must trust...



A thought experiment

Imagine a major terrorist attack in New York: what sorts of limits on the police would be **thrown aside** in the aftermath?



Escrowed encryption offered

Few choose it voluntarily

Pressure to make it pay

Ban on non-escrowed encryption

- Escrow is hard to imagine working **without legal pressure**
- The obvious next step: **ban non-escrowed** encryption, the only way to force sophisticated criminals to use it

Open questions

How hard would such a ban be? How would it affect cryptography as an **academic discipline**? Would a researcher need a **special licence** to study non-escrowed algorithms?



Lesson 8

Legal Issues



Notarization or Signature

Assurance or Availability

Confidentiality

Data integrity

Non-repudiation

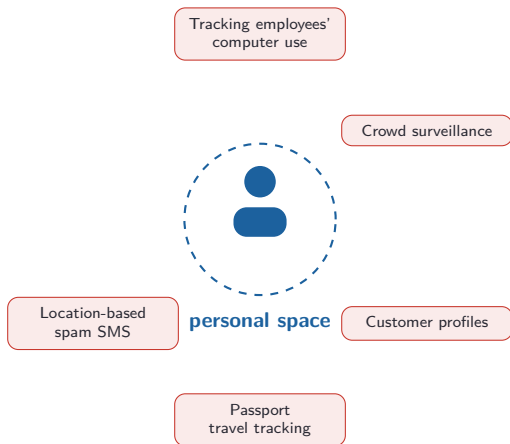
Access control

Authentication

- You know the **OSI network model**: seven layers from physical to application
- A much less known standard on similar lines is the **OSI standard for Security Model**
- It also defines **seven layers of security**, shown on the left

Link to Module 2

These match the **security services** we studied: authentication, access control, integrity, confidentiality, availability and non-repudiation.



- Many ethical and legal issues are about the **individual's right to privacy** versus the **greater good** of a company or society
- Examples are shown around the person on the left

Key concept

To resolve such issues, ask: what is the person's **expectation of privacy**?

Four Ethical Categories: PAPA



Privacy

The right of an individual to **control** personal information



Accuracy

Responsibility for the **authenticity, fidelity and accuracy** of information



Property

Who **owns** the information, and who controls access



Accessibility

What information an organization may **collect**, and how it is safeguarded

Classically, ethical issues in security systems fall into these four categories. Remember them as **PAPA**.



Definition

Privacy is the protection of **personal or sensitive information**: the desire to be **left alone**, as an extension of our personal space.

- It may or may not be **supported by local laws**
- Privacy is **subjective**: different people have different ideas of it
- People trade different amounts of privacy for **safety or convenience**

A Hierarchy of Regulatory Bodies



International

e.g. International Cyber Crime Treaty

Federal (national)

e.g. FERPA, GLB, HIPAA, DMCA, TEACH Act, Patriot Act, Sarbanes-Oxley

State

e.g. UCITA, SB 1386

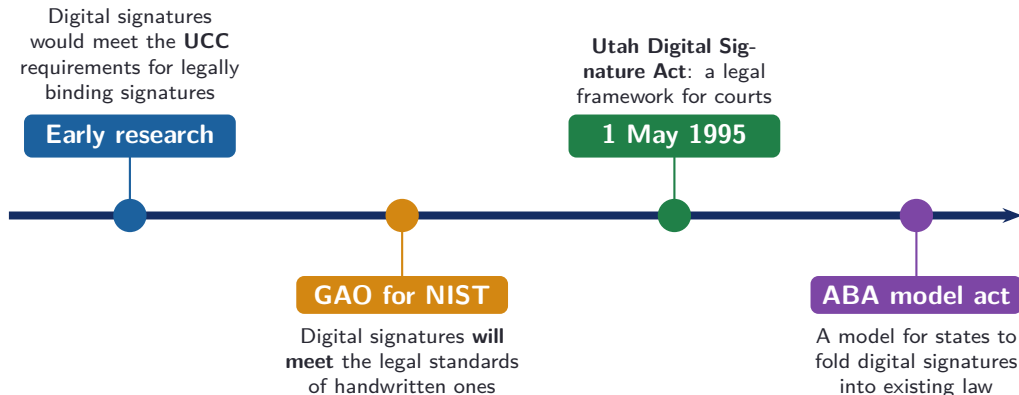
Organization

e.g. Computer use policy

Remember

Legal issues are governed by a **hierarchy**: an organization's policy must obey state law, which must obey national law, which must fit international treaties.

Are Digital Signatures Real Signatures?



UCC = Uniform Commercial Code; GAO = General Accounting Office; ABA = American Bar Association.



The model act includes

- Fitting digital signatures into existing law: UCC, US Federal Reserve rules, contract law, UN conventions on sale of goods and bills of exchange
- Responsibilities and obligations of **certification authorities**
- Issues of **liability**, limits and policies

Still undefined

In the US, signature and contract laws are **state** laws, so the act targets states; a federal act is the eventual goal. The validity of digital signatures had **not yet been tested in court**.

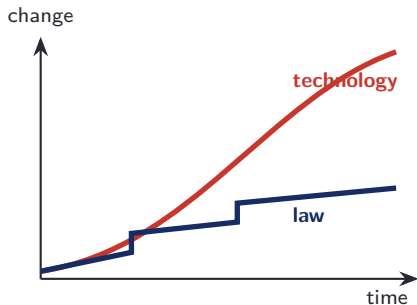


precedent builds up case by case

Until Courts Decide: The Paper Contract

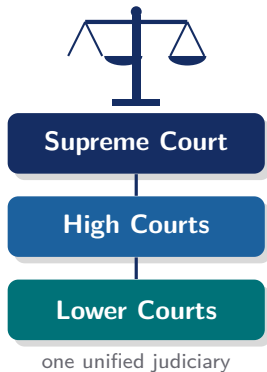


- For digital signatures to have the same authority as handwritten ones, they must first be used, **challenged in court**, and ruled on, again and again
- A body of **precedent** would then say which methods and key sizes are legally binding; this takes years
- Until then: first sign a **paper contract** agreeing to honour your digital signatures



- As security changes our lives, laws enable desired behaviour and prohibit undesired behaviour
- But information technology moves **much faster** than law-making
- Sometimes laws are **too restrictive** (import/export of encryption)
- Sometimes **too slow** (digital signatures)
- Sometimes both (privacy laws)

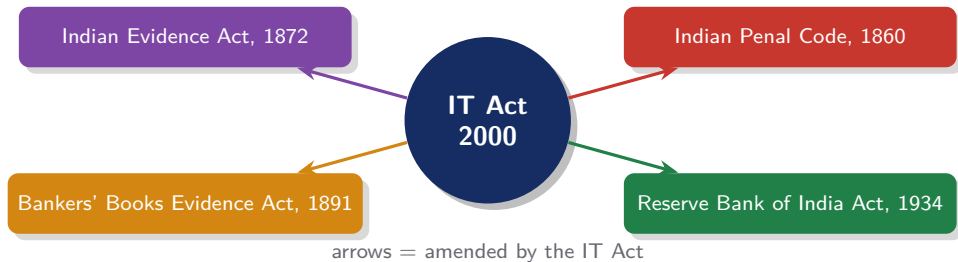
You will never satisfy everyone with a law, but it does set the rules of the game.



- India has a detailed legal system based on **English common law**
- Older laws did not cover the **Internet** and **offshoring**, which created complex new legal issues
- The government responded **proactively**: first draft of the IT Bill in **1999**, the **IT Act** in **2000**
- The **Copyright Act** covers computer programs

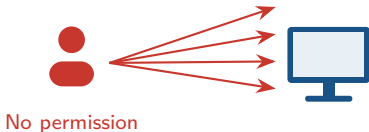
No specific data-protection law

Instead, several **proxy laws** provide indirect safeguards, as we will see.



Background

Passed by both houses of Parliament in **May 2000**. It covers **cyber and IT-related laws** in India, and updated older acts with its provisions.



Penalty up to Rs. 1 crore

Section 43

If a person, **without permission** of the person in charge of a computer system:

- accesses it,
- downloads any data,
- introduces a virus, or
- causes denial of access,

they are liable for a penalty of up to **Rs. 10 million** (1 crore).



Section 65: Tampering with Source Code

```
int main() {  
    // check_licence();  
}
```

Knowingly **hiding, destroying or altering** computer source code, or getting someone else to.

Up to **3 years** jail, or fine
up to **Rs. 2 lakh**, or both

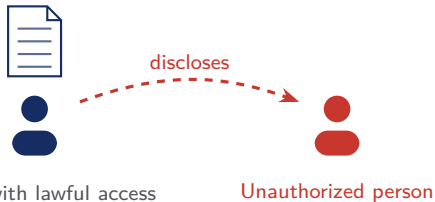
Section 66: Hacking



computer resource

With intent to cause **wrongful loss or damage**, destroying, deleting or altering information, reducing its value or utility, or harming it by any means.

Up to **3 years** jail, or fine
up to **Rs. 2 lakh**, or both



2 years and/or Rs. 1 lakh

Breach of confidentiality and privacy

A person who got access to an electronic record, register, correspondence or document **under powers granted by the IT Act**, and discloses it to another person **without consent**.

Note

It does **not** cover personal information disclosed by a website or e-mail service provider.



Section	Offence	Punishment
43	Unauthorized access, download, virus, denial of access	Penalty up to Rs. 10 million (1 crore)
65	Tampering with computer source code	Up to 3 years and/or Rs. 2 lakh
66	Hacking	Up to 3 years and/or Rs. 2 lakh
72	Breach of confidentiality and privacy	Up to 2 years and/or Rs. 1 lakh

Exam tip: learn the **section number**, the **offence** and the **punishment** together.



buying goods, hiring a builder, borrowing money, ordering machinery

Breach of contract

Contract

A **legally binding agreement** between two or more persons. The parties set its terms and must perform as specified.

Breach

Violating the terms, or not performing one's obligations.

Remedy 1: Damages

Compensation for loss arising **in the usual course** from the breach, not for remote or indirect loss, unless both parties knew it was likely.



Stipulated penalty

If the contract names a sum for breach, the injured party gets reasonable compensation **up to that sum**; courts may reduce it

Specific performance

In special cases the court orders the defaulter to **actually perform** the promised obligation (discretionary)

Injunction

Faster than damages: usually within **a month**, while damages can take **years**

Offshoring to India

Foreign firms protect data and IP mainly through **contracts**. They should sign an exhaustive **Service Level Agreement (SLA)** covering data security and confidentiality.



406

Criminal breach of trust

A person **entrusted** with property dishonestly misappropriates it, uses or disposes of it wrongfully, or induces another to do so.

Up to **3 years**, or fine, or both

420

Cheating

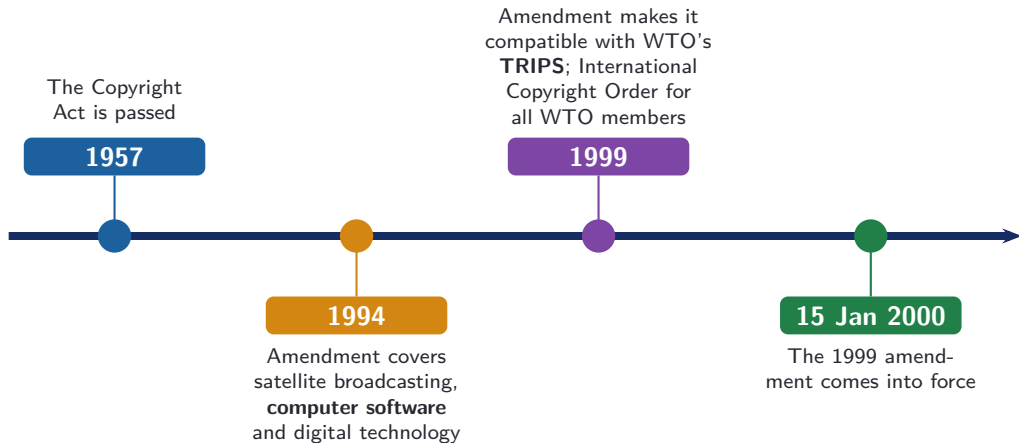
Cheating and dishonestly inducing a person to **deliver property**, or to alter or destroy a valuable security.

Up to **7 years** and a fine

Why in a security course?

An employee who misuses entrusted data, or a fraudster who tricks people online, can be prosecuted under these sections.

Indian Copyright Act: A Timeline



India has one of the **most modern** copyright protection laws in the world. TRIPS = Trade-Related aspects of Intellectual Property Rights.



Using an illegal copy of software

Jail: minimum 7 days, up to 3 years

Fine: Rs. 50,000 to Rs. 2 lakh

or both

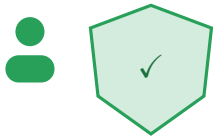
- Anyone who **knowingly** uses an illegal copy of a computer program can be punished under **Section 63B**

Copyright, not patent

In India, software has **copyright** protection but **no patent** protection. A program is an algorithm, and patent law does not protect algorithms.

“Software” includes

Programs, databases, computer files, design material, and printed documentation such as user manuals.



Consumer Protection Act, 1986

In force from **15 April 1986**, to protect consumers from exploitation and poor goods and services.

Consumers can complain of “**deficiency of service**”, e.g. disclosing their information without proper authorization.

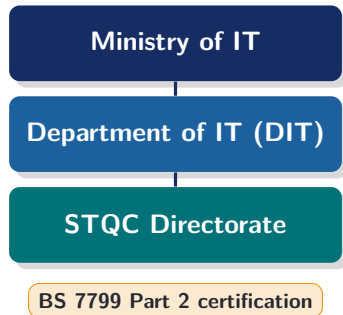


Specific Relief Act, 1963

Under **Section 39**, a person can claim **temporary and permanent injunctions** against the unauthorized disclosure of confidential information.



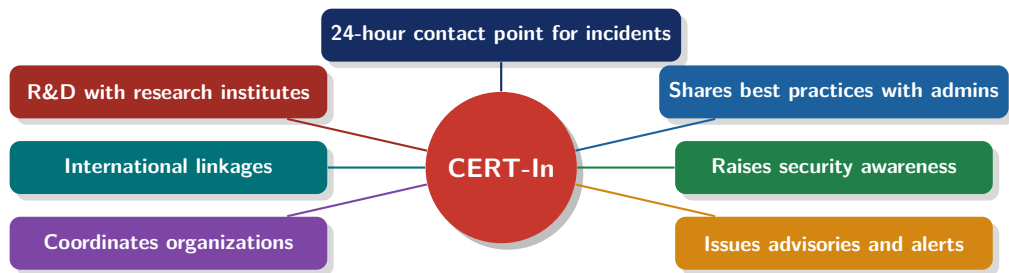
Law	What it helps with
IT Act, 2000	Unauthorized access, virus, hacking, source-code tampering, breach of confidentiality
Indian Contract Act, 1872	Breach of contract and SLAs: damages, penalty, specific performance
Indian Penal Code	Criminal breach of trust (406), cheating (420)
Copyright Act, 1957	Illegal copies of software (63B)
Consumer Protection Act, 1986	Deficiency of service, such as leaking customer data
Specific Relief Act, 1963	Injunctions against disclosure of confidential information (Sec. 39)



Standardization, Testing and Quality Certification

Set up because Indian firms needed internationally accredited security standards.

- Launched an independent third-party certification scheme for **Information Security Management Systems** (BS 7799 Part 2)
- Accredited by **RvA, Netherlands**
- Tests hardware and software, certifies products, and **trains** people in quality and security



Set up by the DIT as part of the **international CERT community**, to protect India's IT assets against viruses and other threats.



Objective

To **facilitate, coordinate and promote** technological advances, and respond to information security incidents, threats and attacks at the **national level**.

1

Evaluate project proposals for DIT

2

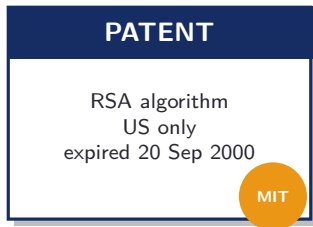
Review ongoing projects; recommend changes

3

Recommend follow-up on completed projects

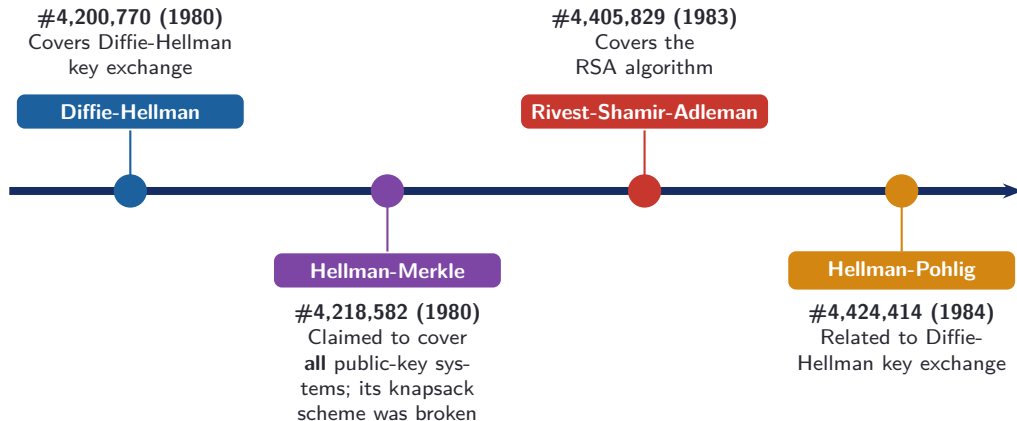
4

Form review and steering groups



- The legal picture changes quickly: “if you’re going to do anything involving cryptography, **talk to a lawyer**”
- Most crypto techniques were **patented**, which slowed their use; being free was a key criterion for choosing **AES**
- **RSA**, developed at MIT, was patented only in the US, licensed by one company, until **20 September 2000**
- **DSS** was promoted as freely licensable, but rival patent claims (Hellman-Merkle, Schnorr) made it murky

Important Crypto Patents (All Expired)





*Mary had a little key
(It's all she could export)
And all the email that she sent
Was opened at the Fort.*

— Ron Rivest

- The US government once placed **severe restrictions** on exporting encryption
- It treated encryption like a **dangerous technology**, like germ warfare or nuclear weapons
- Domestic products could use strong crypto, but had to **interoperate** with weak exportable ones
- This caused bitterness in industry, and fascinating technical designs

Today

Export controls have now been **largely lifted**.



Lesson 5: Key Escrow

- Lawful wiretaps vs. privacy
- Clipper / EES: chip ID, split key, 2 agencies
- Trustee protocol with n trustees and a KDC
- Politics: few advantages, many disadvantages

Lesson 8: Legal Issues

- PAPA; privacy; hierarchy of regulators
- Digital signatures and the law
- IT Act 2000: Sections 43, 65, 66, 72
- Contract Act, IPC, Copyright, Consumer, Specific Relief
- STQC, CERT-In, ISTDC; patents; export controls

Review questions

1. Discuss key escrow in detail.
2. Explain the IT Act, 2000.
3. Describe the Indian Contract Act, 1872.
4. What is the Indian Penal Code?
5. Explain the Indian Copyright Act.
6. What is the Consumer Protection Act?
7. What initiatives has the government taken to upgrade security standards?
8. Write short notes on legal issues.



- ① William Stallings, *Cryptography and Network Security*, PHI Publishers.
- ② Charlie Kaufman, Radia Perlman, *Network Security*, Pearson Education.
- ③ Bruce Schneier, *Applied Cryptography*, John Wiley & Sons.
- ④ Roberta Bragg, *Network Security: The Complete Reference*, TMH.

Thank You! Questions?